



Dr. Ammar Haider
Assistant Professor
School of Computing

CS3002 Information Security



Legal & Ethical Issues in Security

Introduction



- Motivations for studying legal issues:
 - to describe what protection the law provides for computers and data
 - to help you appreciate laws that protect the rights of others with respect to computers, programs, and data
- To minimize liabilities/reduce risks, the information security practitioner must:
 - Understand the current legal environment
 - Stay current with laws and regulations
 - Watch for new and emerging issues

Where laws fit in cyber sec



Protecting computing systems against criminals

- Computer criminals can violate confidentiality, integrity, and availability for computer systems.
- Preventing these violations is better than prosecuting them after the fact. However, if other controls fail, legal action may be necessary.

Protecting code and data

- Copyrights, patents, and trade secrets are forms of legal protection that can be applied to programs and sometimes to data.

Criminal and Civil Law



- Some laws state explicitly that certain actions are illegal.
- A violation of such a law will result in a **criminal** trial, in which the government argues for punishment because an illegal act has harmed society.
 - Law requires that the judge or jury find the accused guilty beyond reasonable doubt. For this reason, the evidence must be strong and compelling.
- In a **civil** case, an individual, organization, company, or group claims it has been harmed.
- The goal of a civil case is restitution: to make the victim “whole” again by repairing the harm.
 - Civil law does not require as high standard of proof of guilt.

Policy Versus Law



- Policies: managerial directives that specify acceptable and unacceptable employee behavior in the workplace
- Policies function as organizational laws; must be crafted and implemented with care to ensure they are complete, appropriate, and fairly applied to everyone
- Difference between policy and law: Ignorance of a policy is an acceptable defense.

Cyber Laws in Pakistan



- Electronic Transaction Ordinance 2002
 - First IT-related legislation
 - Meant for protection of eCommerce business
 - Focused more on legal recognition of electronic documents
- Electronic Crimes Bill 2007
 - Defined several new offences, like electronic forgery, cyberstalking, data damage etc.
- Prevention of Electronic Crimes Act 2016
 - Revised form of 2007 bill
 - Several amendments made in recent years

PECA 2016



- Defines several offenses and punishments
- Applies to
 - All over Pakistan
 - Pakistanis abroad
 - Persons outside Pakistan if they commits an offence affecting Pakistani persons or data
- This act has a wide coverage: it criminalizes actions that harm people, as well as actions that target national security, financial systems, and essential services.

Some Offenses & Punishments



Action	Information / Data	Critical Infrastructure
Unauthorized Access	up to 3 months imprisonment and/or fine of up to Rs 50,000	3 years Rs 1 million
Unauthorized Copy	6 months Rs 1 lac	5 years Rs 5 million
Unauthorized Interference	2 years Rs 5 lac	7 years Rs 10 million

‘Critical infrastructure’ is defined in the act itself, as systems whose compromise could lead to significant loss of life, or serious economic harm, or significant effect on national security.

More offences



- Electronic forgery or fraud
- Using another person's identity
- Distributing and transmitting malicious code (malware)
- Cyber stalking / cyber bullying
 - Intimidating or harassing a person over electronic media
 - Includes blackmailing with inappropriate photo/video
- Spamming
 - Sending unsolicited information without permission from recipient (marketing emails/SMS)

Cognizable Offenses



Following offenses are cognizable, i.e. law enforcement can start arrests and investigation without judicial warrant.

- Cyber terrorism
 - Creating fear/panic in Government or public
 - Penalty of up to 14 year imprisonment and up to 50 million fine
- Offence against dignity of a person
 - e.g. spreading deepfake videos
- Child Pornography

Investigating Agency



- As per latest amendment (2025), a dedicated investigation agency, National Cyber Crime Investigation Agency (NCCIA) was established.
- NCCIA gets exclusive powers to investigate and charge cases against cyber crimes
 - Previously the responsibility was with cybercrime wing of FIA.
 - Provincial police organizations are not authorized

International Laws and Legal Bodies



- When organizations do business on the Internet, they do business globally.
- Professionals must be sensitive to the laws and ethical values of many different cultures, societies, and countries.
- Because of the political complexities of relationships among nations and differences in culture, few international laws cover privacy and information security.
- These international laws are important but are limited in their enforceability.

WTO TRIPS Agreement



- TRIP = Trade-Related Aspects of Intellectual Property Rights
- Created by the World Trade Organization (WTO)
- The first significant international effort to protect intellectual property rights; outlines requirements for governmental oversight and legislation providing minimum levels of protection for intellectual property.
- Agreement covers five issues:
 - Application of basic principles of trading system and international intellectual property agreements
 - Giving adequate protection to intellectual property rights
 - Enforcement of those rights by countries within their borders
 - Settling intellectual property disputes between WTO members
 - Transitional arrangements while new system is being introduced

Digital Millennium Copyright Act (DMCA)



- U.S. contribution to international effort to reduce impact of copyright, trademark, and privacy infringement
- A response to European Union Directive 95/46/EC
- Prohibits
 - Circumvention of protections and countermeasures
 - Manufacture and trafficking of devices used to circumvent such protections
 - Altering information attached or embedded in copyrighted material
- Excludes Internet Service Providers (ISPs) from some copyright infringement

Detering illegal behavior



- Three general causes of illegal behavior: ignorance, accident, intent
- Deterrence: best method for preventing an illegal activity; for example, laws, policies, technical controls
- Laws and policies only deter if three conditions are present:
 - Fear of penalty
 - Probability of being apprehended
 - Probability of penalty being applied

Deterrents to illegal behavior



Penalty



Apprehension



Application



Ethical Issues



Laws are not sufficient



- The law is not always the appropriate way to deal with issues of human behavior.
- It is difficult to define a law to preclude only some events and enable other events.
 - For example, a law that restricts animals from public places must be 'refined' to permit service dogs
- Lawmakers, who are not usually computer professionals, are hard pressed to think of all possible exceptions when they draft a law concerning computer affairs.
- Even when a law is well conceived and well written, its enforcement may be difficult.

Laws are not sufficient



- What is desirable today may become undesirable tomorrow, as societal needs change and as computing is used in new ways.
- In addition, reliance on legal recourse can be time consuming and unsatisfactory.
 - The courts are overburdened, and the resources needed to prosecute relatively minor infractions may be excessive compared to the benefit.
- Thus, it is impossible or impractical to develop laws to describe and enforce all forms of behavior acceptable to society.
- Instead, society relies on **ethics** to prescribe generally accepted standards of proper behavior.

What ethics means



- An ethic is an ‘objectively’ defined standard of right and wrong.
 - i.e., ethical standards are often idealistic principles because they focus on a single objective.
- In a given situation, however, several objectives may be involved, so we have to balance multiple (sometimes conflicting) objectives to determine an appropriate action.
- Regardless of our religious and professional affiliations, each of us is responsible for deciding what to do in a specific situation.
- Through our choices as individuals, we define a personal set of ethical practices.

Laws vs Ethics



Laws	Ethics
Described by formal, written documents	Described by written and unwritten principles
Established by legislatures representing all people	Presented by philosophers, religions, professional groups
Priority determined by courts if two laws conflict	Priority determined by an individual if two principles conflict
Enforced by police and courts	Enforced by intangibles such as principles and beliefs

Ethical principles are not universal



- Ethical values vary by society / culture and from person to person within a society.
 - For example, the concept of privacy is important in western cultures. But in eastern cultures, privacy is not necessarily desirable; people associate privacy with having something to hide.
- Also, an individual's standards of behavior may be influenced by past life events.

Ethics does not provide clear answers



- We must recognize that more than one position may be ethically justifiable—even equally so—in a given situation.
 - It is similar to the way we expect and accept disagreement in areas like politics and religion.
- Worse, there is no higher authority of ethical truth.
 - Two people may disagree on their opinion of the ethics of a situation, but there is no one to whom to appeal for a final determination of who is “right.”
- Still, conflicting answers should not deter one from considering ethical issues in computer security.
- Nor do they excuse us from making and defending ethical choices.

Incident Analysis with Ethics



- To understand how ethics affects professional actions, ethicists often study example situations.
- You should reflect on each case, determining for yourself what the most influential points are.
- Remember that ethics are not determined by majority rule. Those siding with the majority are not “right,” and the rest are not “wrong.”

Example Situation 1



- David works as a programmer for a large software company. He writes and tests utility programs.
- His company operates two computing shifts: During the day, program development and online applications are run; at night, offline production jobs are completed.
- David has access to resource usage data and learns that the evening runs are complementary to daytime programming tasks; that is, adding programming work during the night shift would not adversely affect performance of the computer to other users.

Example Situation 1



- David comes back after normal hours to develop a program to manage his own stocks portfolio.
- His drain on the system is minimal, and he uses very few expendable supplies.
- **Is David's behavior ethical?**

Principles Involved



- **Ownership of resources:** The company owns the computing resources and provides them for its own computing needs.
- **Effect on others:** Although unlikely, a flaw in David's program could adversely affect other users, perhaps even denying them service because of a system failure.
- **Universalism:** If David's action is acceptable, it should also be acceptable for others to do the same. However, too many employees working in the evening could reduce system effectiveness.
- **Possibility of detection, punishment:** David does not know whether his action would be wrong or right if discovered by his company. If his company decided it was improper use, he could be punished.

What other issues are involved? Which principles are more important than others?

Example Situation 2



- Donald works for the county records department as a computer records clerk, where he has access to files of property tax records.
- For a scientific study, a researcher, Ethel, has been granted access to the numerical portion—but not the corresponding names—of some records.
- Ethel finds some information that she would like to use, but she needs the names and addresses corresponding with certain properties.
- Ethel asks Donald to retrieve the names and addresses so she can contact these people for more information and for permission to do further study.
- **Should Donald release the names and addresses?**

Principles Involved



- **Job responsibility:** Donald's job is to manage individual records, not to make determinations of appropriate use. Policy decisions should be made by someone of higher authority.
- **Use:** The records are used for legitimate scientific study, not for-profit or to expose sensitive data.
- **Possible misuse:** Although he believes Ethel's motives are proper, Donald can not guarantee that Ethel will use the data only to follow up on interesting data items.
- **Confidentiality:** Had Ethel been intended to have names and addresses, they would have been given initially.

Principles Involved



- **Tacit permission:** Ethel has been granted permission to access parts of these records for research purposes, so she should have access to complete her research.
- **Propriety:** Because Ethel has no authority to obtain names and addresses and because the names and addresses represent the confidential part of the data, Donald should deny Ethel's request for access.

Example Situation 3



- Goli is a computer security consultant; she enjoys the challenge of finding and fixing security vulnerabilities.
- Independently wealthy, she does not need to work, so she has ample spare time in which to test the security of systems. In her spare time, Goli does two things:
- First, she aggressively attacks commercial products for vulnerabilities. She is quite proud of the tools and approach she has developed, and she is quite successful at finding flaws.
- Second, she probes accessible systems on the internet, and when she finds vulnerable sites, she contacts the owners to offer her services repairing the problems.

Principles Involved



Action 1: attacking commercial desktop software

- As per **rule-based ethics** , clearly, the attackers are wrong to perform malicious attacks.
- But let us analyze using **consequence based ethics** : Who is helped or hurt by finding and publicizing flaws in products?
- Relevant parties are attackers (the vulnerability finder), the vendor, and the using public.
- From consequence perspective, notoriety or credit for finding the flaw is a small interest. And the interests of the vendor (financial, public relations) are less important than the interests of users to have secure products.

Principles Involved



- But how are the interests of users best served?

a) Full disclosure.

- This approach helps users assess the seriousness of the vulnerability and apply appropriate protection. But it also gives attackers more information with which to formulate attacks. Early full disclosure—before the vendor has countermeasures ready—may actually harm users by leaving them vulnerable to a now widely known attack.

Principles Involved



b) Partial disclosure.

- This reveals the general nature of the vulnerability but not a detailed exploitation scenario, which may forestall attackers.
- One can argue that the vulnerability details are there to be discovered; when a vendor announces a patch for an unspecified flaw in a product, the attackers will test that product aggressively and study the patch carefully to try to determine the vulnerability.
- Attackers will then spread a complete description of the vulnerability to other attackers through an underground network, and attacks will start against users who may not have applied the vendor's fix.

Principles Involved



c) No disclosure.

- Perhaps users are best served by a scheme in which every so often new code is released, sometimes fixing security vulnerabilities, sometimes fixing things that are not security related, and sometimes adding new features.
- But without a sense of significance or urgency, users may not install this new code.
- Worse yet, vendors will slack and not prioritize fixing the vulnerability, users will stay vulnerable for a long time.

Principles Involved



Action 2: searching for vulnerabilities in online services

- Again, the party of greatest interest is the user community and the good or harm that can come from the search.
- On the positive side, searching may find vulnerabilities.
- Clearly, it would be wrong for Goli to report vulnerabilities that were not there simply to get work.
- And it would also be wrong to report some but not all vulnerabilities to be able to use the additional vulnerabilities as future leverage against the client.

Principles Involved



- But suppose Goli does a diligent search for vulnerabilities and reports all to the potential client.
- Is that not similar to a service station owner's advising you that a headlight is not operating when you take your car in for fuel?
 - Not quite, you might say. The headlight flaw can be seen without any possible harm to your car; probing for vulnerabilities might cause your system to fail.
- The ethical question seems to be which is greater: the potential for good or the potential for harm? And if the potential for good is stronger, how much stronger does it need to be to override the risk of harm?

Principles Involved



- In addition, the **intent** of hacker can also be considered.
- Hackers see whether they can access your system without your permission, perhaps by guessing a password.
- Many crackers simply want to look around, without damaging anything. One can compare this seemingly innocent activity with entry into your house when the door is left unlocked.

How to act ethically



- The important first step in acting ethically in a situation is to obtain the facts, ask about any uncertainties, and acquire any additional information needed.
 - In other words, first we must understand the situation.
- The second step is to identify the ethical principles involved. Honesty, fair play, proper compensation, and respect for privacy are all ethical principles. Sometimes these conflict, and then we must determine which principles are more important than others.
 - This analysis may not lead to one principle that obviously overshadows all others. Still, a rough ordering to identify the major principles involved is needed.

How to act ethically



- The third step is choosing an action that meets these ethical principles. Making a decision and taking action are difficult, especially if the action has evident negative consequences. However, taking action based on a personal ranking of principles is necessary.
- The fact that other equally sensible people may choose a different action does not excuse us from taking some action.
- Only by recognizing and analyzing principles can you act consistently, thoughtfully, and responsibly.

Ethics and Education



- Education is the overriding factor in leveling ethical perceptions within a small population.
- Employees must be trained and kept aware of the expected behavior of an ethical employee, as well as many other information security topics.
- Proper ethical training is vital to creating informed and a well-prepared system user.

Ethics and Information Security



- Many professional disciplines have explicit rules governing the ethical behavior of members.
- IT and InfoSec do not have binding codes of ethics.
- Professional associations and certification agencies work to maintain ethical codes of conduct.
 - Can **prescribe** ethical conduct
 - Do not always have the ability to ban violators from practice in field

Ten Commandments



The Ten Commandments of Computer Ethics from the Computer Ethics Institute

1. Thou shalt not use a computer to harm other people.
2. Thou shalt not interfere with other people's computer work.
3. Thou shalt not snoop around in other people's computer files.
4. Thou shalt not use a computer to steal.
5. Thou shalt not use a computer to bear false witness.
6. Thou shalt not copy or use proprietary software for which you have not paid.

Ten Commandments



7. Thou shalt not use other people's computer resources without authorization or proper compensation.
8. Thou shalt not appropriate other people's intellectual output.
9. Thou shalt think about the social consequences of the program you are writing or the system you are designing.
10. Thou shalt always use a computer in ways that ensure consideration and respect for your fellow humans.

Professional Organizations for Information Security Professionals



Professional Organization	Web Resource Location	Description	Focus
Association of Computing Machinery	<u>www.acm.org</u>	Code of 24 imperatives of personal and ethical responsibilities for security professionals	Ethics of security professionals
Information Systems Audit and Control Association	<u>www.isaca.org</u>	Focus on auditing, information security, business process analysis, and IS planning through the OSA and OSM certifications	Tasks and knowledge required of the information systems audit professional
Information Systems Security Association	<u>www.issa.org</u>	Professional association of information systems security professionals; provides education forum, publications, and peer networking for members	Professional security information sharing

Professional Organizations for Information Security Professionals



Professional Organization	Web Resource Location	Description	Focus
International Information Systems Security Certification Consortium (ISC ²)	<u>www.isc2.org</u>	International consortium dedicated to improving the quality of security professionals through SSCP and CISSP certifications	Requires certificants to follow its published code of ethics
SANS Institute's Global Information Assurance Certification	<u>www.giac.org</u>	GIAC certifications focus on four security areas: security administration, security management IT audits, and software security, these areas have standard, gold, and expert levels	Requires certificants to follow its published code of ethic

Major IT and InfoSec Professional Organizations (1 of 5)



- Association of Computing Machinery (ACM)
 - Established in 1947 as “the world’s first educational and scientific computing society.”
 - Code of ethics contains references to protecting information confidentiality, causing no harm, protecting others’ privacy, and respecting others’ intellectual property and copyrights.

Major IT and InfoSec Professional Organizations (2 of 5)



- International Information Systems Security Certification Consortium, Inc. (ISC)²
 - Nonprofit organization focusing on the development and implementation of information security certifications and credentials.
 - Code is primarily designed for the information security professionals who have certification from (ISC)².
 - Code of ethics focuses on four mandatory canons.

Major IT and InfoSec Professional Organizations (3 of 5)



- SANS (originally System Administration, Networking, and Security Institute)
 - Professional organization with a large membership dedicated to the protection of information and systems.
 - SANS offers a set of certifications called Global Information Assurance Certification (GIAC).

Major IT and InfoSec Professional Organizations (4 of 5)



- ISACA (originally Information Systems Audit and Control Association)
 - Professional association with focus on auditing, control, and security
 - Concentrates on providing IT control practices and standards
 - ISACA has a code of ethics for its professionals

Major IT and InfoSec Professional Organizations (5 of 5)



- Information Systems Security Association (ISSA)
 - Nonprofit society of InfoSec professionals
 - Primary mission to bring together qualified IS practitioners for information exchange and educational development
 - Promotes code of ethics similar to (ISC)², ISACA, and ACM

References



- Pfleeger, Security in Computing, chap 11
- Whitman chap 3
- PECA 2016 full text:
https://sia.gos.pk/assets/Acts_Ordinances_Rules2/PEC2016.pdf
- Criticism on PECA law
 - <https://www.amnesty.org/en/latest/news/2022/02/pakistan-repeal-draconian-cyber-crime-law/>
 - https://www.nchr.gov.pk/press_release/statement-against-the-prevention-of-electronic-crimes-amendment-ordinance-2022/
 - <https://cfj.org/news/deep-flaws-in-pakistans-cyber-defamation-law-threaten-press-freedom/>
 - <https://www.dawn.com/news/1914865>